

SAP ITGC Automation Tool

Proof of Concept: Document

Version 1.4 | Date: 15 June 2026 | Updated by: Rajat Chaudhary

Prepared for management review, PoC validation, pilot approval, and company-level scalability assessment

Version Control Matrix

S.no	Version No.	Last Updated By	Last Updated Date
1	Version 1.3	Arihan Deshwal	12-06-2026
2	Version 1.4	Rajat Chaudhary	15-06-2026

1. Executive Summary

This Proof of Concept (PoC) document presents the SAP ITGC Automation Tool developed by the GAD IT Team as a limited but functional audit enablement solution for SAP ITGC testing. The tool is designed to support audit teams in executing selected SAP ITGC procedures across Change Management, Access Management, and IT Operations by validating uploaded SAP extracts, applying repeatable testing logic, generating structured outputs, and maintaining audit trail records.

The current prototype demonstrates that repetitive and evidence-driven SAP ITGC procedures can be partially or substantially automated using standard SAP extracts such as E070, STMS, SUIM, USR02, RSPARAM, DD09L, DD02L, and SM37. The tool currently includes implemented logic for several controls, assisted review for OCR-based SCC4 validation, and a placeholder for future backup and recovery testing.

The purpose of this PoC is to seek management support to validate, enhance, and scale the tool into a company-level audit accelerator. With appropriate methodology review, technology support, secure deployment, governance, and pilot testing, the tool can improve audit consistency, reduce manual effort, strengthen documentation quality, and create reusable firm-level intellectual property for SAP ITGC engagements.

2. Background and Current State

- SAP ITGC testing is currently performed across multiple engagements using a combination of manual evidence review, Excel-based analysis, auditor judgment, and engagement-specific templates.
- Testing procedures and documentation quality may vary depending on the experience of the engagement team, availability of SAP subject matter expertise, and consistency of client-provided extracts.
- A significant amount of audit time is spent on repetitive activities such as validating mandatory columns, identifying control populations, grouping user access events, comparing SAP parameter values, reviewing job status, and documenting exception patterns.
- The same or similar SAP extracts are repeatedly requested and reviewed across engagements, creating a strong opportunity for standardization and automation.
- There is a need for a scalable solution that can guide teams, reduce dependency on individual experience, and support consistent execution of SAP ITGC testing across the company.

3. Problem Statement

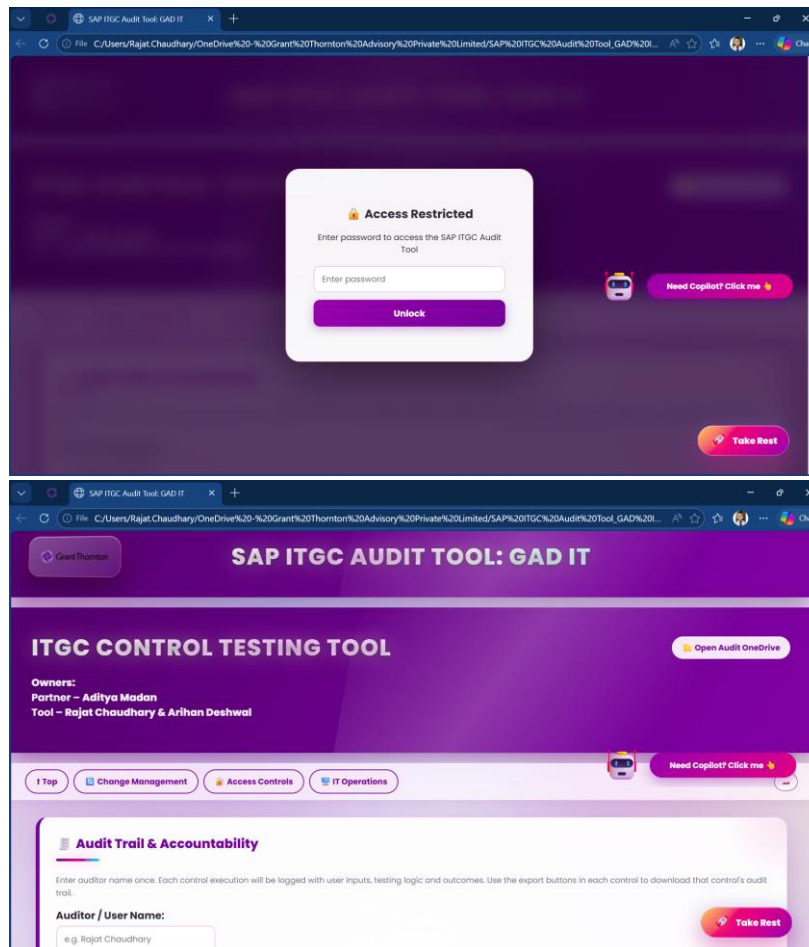
Current SAP ITGC testing involves significant manual intervention and engagement-specific interpretation. This may result in increased execution time, inconsistent documentation, higher review effort, and risk of missing key testing steps or exception patterns. A standardized, scalable, and audit-grade tool is required to assist teams in performing repeatable SAP ITGC procedures more efficiently while preserving auditor judgment for final conclusions.

4. Objectives of the PoC

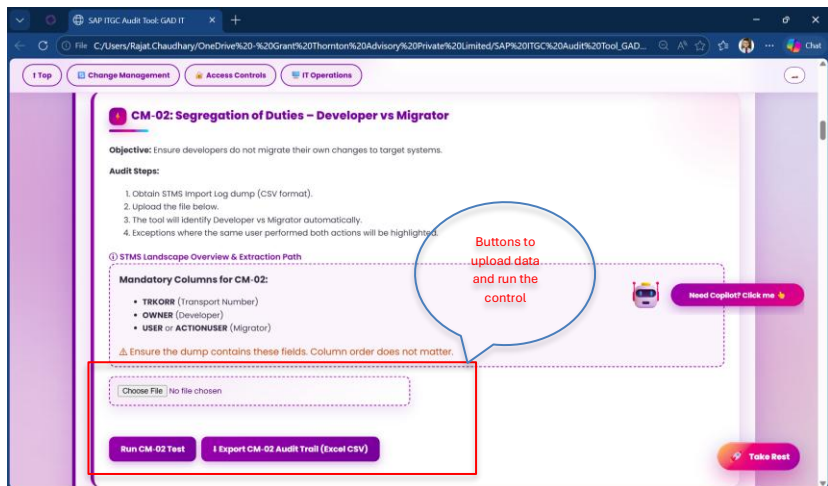
- Demonstrate the feasibility of automating selected SAP ITGC testing procedures using standard SAP extracts.
- Standardize audit steps, evidence expectations, and output formats across SAP ITGC engagements.
- Reduce manual effort in population identification, mandatory field validation, data grouping, and exception identification.
- Improve consistency and completeness of audit documentation and audit trail generation.
- Enable management to assess whether the tool can be enhanced and deployed as a company-level audit accelerator.
- Identify the functional, technical, security, methodology, and governance requirements required for enterprise adoption.

5. Tool Navigation & Common Features

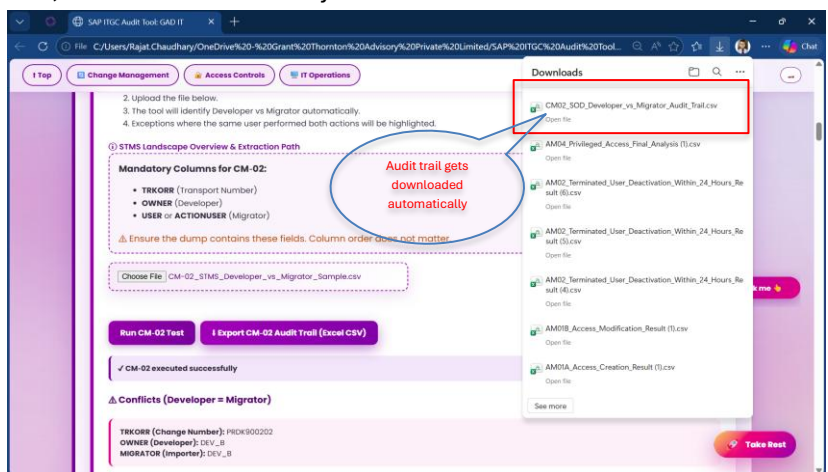
- **Password gate:** The tool opens behind an access restriction screen and requires the configured password to enter.



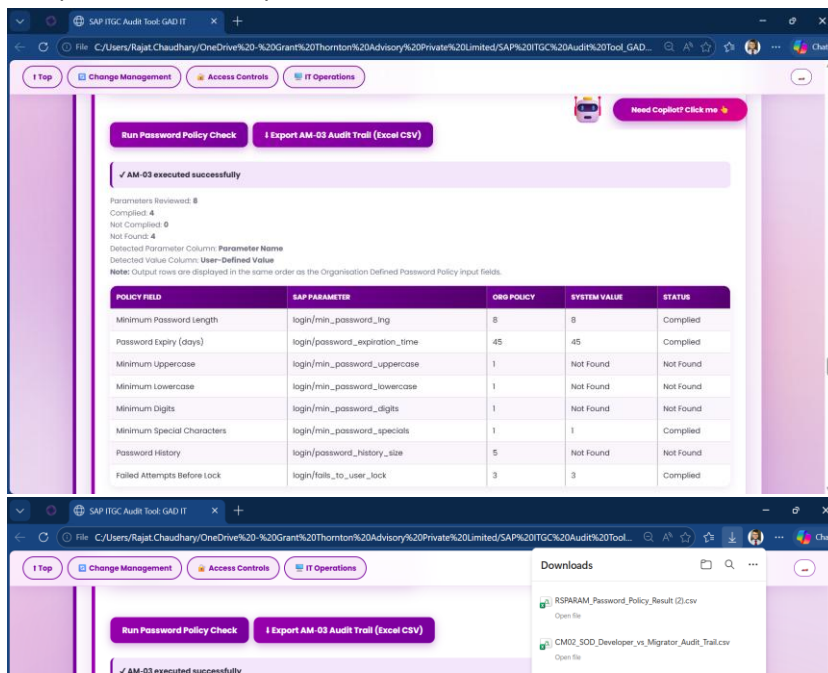
- **Control cards:** Each control is presented in a separate card with objective, audit steps, mandatory columns, upload fields, run button, and output area.



- **Audit trail:** Execution details are logged with control ID, control name, inputs, logic summary, population/sample size, and outcome summary.



- **Per-control export:** Each control includes an export option for its specific audit trail; the tool also provides a complete audit trail export.



- **Evidence format:** The tool is primarily designed for CSV / text-style SAP extracts. Column names are matched flexibly where implemented, but auditors should preserve the expected SAP/client headers wherever possible.

6. Scope of Current PoC

6.1 SAP ITGC Domains Covered

- Change Management
- Access Management
- IT Operations

6.2 Current Control Coverage Matrix

Control ID	Control Name	Area	Primary Evidence	Testing Mode	Implementation Status
CM-01	Identification of Changes	Change Management	E070 Transport Header Extract	Automated population identification and sampling support	Implemented up to sampling
CM-02	Developer vs Migrator SOD	Change Management	STMS Import Log	Automated exception identification	Implemented completely
CM-03	Developer Access to Production	Change Management	DEVACCESS or equivalent production extract	Automated identification based on developer access indicators	Implemented completely
CM-04	SCC4 Client Settings	Change Management	SCC4 screenshot	OCR-assisted review	Implemented; to be enhanced through AI
CM-05	Table Logging & Modifiability	Change Management	DD09L and DD02L extracts	Automated comparison of logging and modifiability indicators	Implemented completely
AM-01A	Access Creation	Access Management	SUIM Change Documents - For Users	Automated identification of user creation events	Implemented completely
AM-01B	Access Modification	Access Management	SUIM Change Documents - For Users	Automated identification and grouping of access modification events	Implemented completely
AM-02	Terminated User Deactivation	Access Management	HR Exit listing, USR02 extract, optional SM20	Automated matching and deactivation assessment	Implemented completely
AM-03	Password Policy Review	Access Management	RSPARAM parameter extract	Automated parameter comparison	Implemented completely

AM-04	Privileged Access Review	Access Management	SAP_ALL, SAP_NEW, SU01/SU02, SU10, STMS, SCC4, SM30/SM31, SE06, SE38 extracts	Automated aggregation and privilege reporting	Implemented completely
OPS-01	SAP Job Monitoring & Batch Processing	IT Operations	SM37 job monitoring dump	Automated job status validation	Implemented completely
OPS-02	SAP Backup and Recovery	IT Operations	Backup/recovery evidence	Placeholder only	Not implemented yet

7. Business Benefits and Value Proposition

Benefit Area	Expected Value
Efficiency	Reduces manual effort for repetitive data validation, population identification, grouping, comparison, and exception listing activities.
Audit Quality	Promotes consistent execution of SAP ITGC procedures and reduces risk of missing standard testing steps.
Documentation	Generates structured outputs and audit trail records that can support workpaper preparation and review.
Review Effectiveness	Improves reviewer visibility through standardized logic summaries, control-wise results, and clear exception outputs.
Team Enablement	Supports junior team members by providing control-wise objectives, evidence requirements, and testing guidance.
Scalability	Can be reused across multiple SAP ITGC engagements and enhanced into a firm-level audit accelerator.
Innovation	Demonstrates technology-led audit delivery and creates reusable company intellectual property.

8. Current Limitations and Out-of-Scope Areas

- The current version is a prototype and is not yet hosted in an enterprise-approved environment.
- The tool does not currently connect directly to SAP systems or extract data automatically from SAP tables.
- The tool can only test the data uploaded; incomplete, filtered, or incorrect extracts may result in incomplete conclusions.
- Column mapping is dependent on expected SAP/client headers; materially different formats may require mapping review before testing.
- Approval evidence, business justification, ticket evidence, and management review evidence still require auditor review outside the tool.
- CM-04 SCC4 review is OCR-assisted and indicative; final validation must be performed manually against source evidence.
- AM-03 password thresholds must be aligned with client policy before final sign-off.
- OPS-02 backup and recovery testing is currently a placeholder and requires future design and implementation.
- Enterprise features such as SSO, role-based access control, centralized logging, audit-grade security testing, and formal release management are not yet implemented.

9. Governance and Ownership Model Required for Scale-Up

Governance Component	Current SPOCs	Description
Business Owner	Ankit Chugh, Aditya Madan & Ajay Gupta	IT audit business owners responsible for tool vision, prioritization, adoption, and methodology alignment.
Methodology Review	Ankit Chugh, Aditya Madan & Ajay Gupta	SAP ITGC SMEs
Technical Owner	Suyash Korde, Rajat Chaudhary, Arihan Deshwal & Vaishali Giri	Technology team for code, defect fixes, and enhancement releases.
Version Control	Rajat Chaudhary & Arihan Deshwal	Maintain formal version history, change logs and release notes.
Access Governance	TBC post deployment of the tool	Implement role-based access, approved user provisioning, and periodic access review once deployed centrally.
Data Governance	TBC post deployment of the tool	Define clear rules for client data handling, data retention, data deletion, and permitted evidence uploads.
Feedback Mechanism	TBC post deployment of the tool	Create a feedback channel for engagement teams to report issues, improvement ideas, and new use cases.
Periodic Review	TBC post deployment of the tool	Review the tool periodically for methodology changes, SAP version changes, control updates, and regulatory expectations.

10. Risks, Considerations, and Mitigation Plan

Risk / Consideration	Potential Impact	Recommended Mitigation
Client data security	Unauthorized handling of sensitive evidence may create confidentiality risk.	Deploy only on approved infrastructure with access controls, encryption, and data retention rules.
Over-reliance on tool output	Auditors may treat tool results as final conclusion without reviewing evidence context.	Embed disclaimers, require reviewer sign-off, and position the tool as audit support rather than auditor replacement.
Incomplete extracts	Tool may not identify all exceptions if evidence population is incomplete.	Include completeness checks, mandatory column validations, and auditor responsibility guidance.
Inconsistent adoption	Teams may continue using manual approaches or different templates.	Run pilot sessions, provide training, and align templates with audit workpaper expectations.
Maintenance ownership gap	Tool may become outdated without defined ownership.	Nominate business and technical owners and establish change management governance.

11. Proposed Future Enhancements

11.1 Technical Enhancements

- Company-approved hosting environment.
- Single Sign-On and role-based access control.

- Centralized audit logging and usage analytics.
- Data upload controls, file validation, and secure storage or no-storage processing model.
- Integration with SharePoint, Teams, Excel, Power BI, Alteryx, or audit documentation platforms where feasible.
- Formal testing, vulnerability assessment, release management, and support model.

11.2 AI / Copilot-Enabled Enhancements

- AI-assisted evidence review for screenshots and unstructured support.
- Automated exception summarization and draft audit observations.
- Suggested audit conclusions based on uploaded evidence and predefined methodology guardrails.
- Natural language query capability over uploaded extracts and control results.
- Smart risk scoring and prioritization of high-risk exceptions for reviewer attention.

12. Success Criteria for Pilot and Company-Level Rollout

While initial internal testing has been performed by the GAD IT team, the success criteria for the pilot phase and subsequent company-level rollout are defined as follows:

Success Metric	Illustrative Measurement
Efficiency improvement	Reduction in time spent on selected SAP ITGC testing procedures compared with manual testing.
Documentation consistency	Improved standardization of control-wise outputs, audit trail, and exception summaries.
Review quality	Reduction in avoidable review comments related to incomplete procedures or inconsistent documentation.
Adoption	Number of pilot engagements and users actively using the tool.
Control coverage	Number of SAP ITGC controls validated and approved for repeatable use.
User feedback	Positive feedback from engagement teams, reviewers, and SAP ITGC SMEs.
Scalability readiness	Completion of security, methodology, deployment, and governance prerequisites.

13. Proposed Roadmap

Phase	Indicative Timeline	Key Activities	Outcome
Phase 1: PoC Validation	1 weeks	Management review, SME validation, methodology review, limitation assessment.	Approved PoC scope and pilot readiness.
Phase 2: Pilot Rollout	2 weeks	Deploy to selected engagements, run parallel testing, collect feedback and metrics.	Pilot results and enhancement backlog.
Phase 3: Central Development	2 weeks	Improve logic, UI, exports, security, hosting, access controls, and documentation.	Enterprise-ready beta version.
Phase 4: Company-Level Deployment	3 weeks	Central deployment, training, adoption plan, governance implementation.	Reusable audit accelerator available across approved teams.

Phase 5: Continuous Improvement	Ongoing	Add AI, analytics, dashboards, additional SAP controls, and other ERP coverage.	Sustained innovation and scalable audit automation.
---------------------------------	---------	---	---

14. Support Required from Management

Support Area	Specific Ask
Sponsorship	Approval to formally progress the tool from limited prototype to company-level PoC/pilot.
Methodology Support	Nomination of SAP ITGC SMEs and quality reviewers to validate control logic and audit outputs.
Technology Support	Developer/IT support for secure hosting, authentication, code review, testing, and deployment.
Security and Risk Review	Guidance on client data handling, access control, retention, confidentiality, and approved infrastructure.
Pilot Engagements	Nomination of pilot engagements and users for controlled testing.
Budget / Capacity	Allocation of time and resources for enhancement, documentation, training, and support.
Adoption Support	Endorsement for wider usage if pilot success criteria are achieved.

Annexure: Detailed Control Manual

CM-01 – Identification of Changes (E070)

Item	Description
Control Area	Change Management
Objective	Identify and classify SAP changes released during the audit period using the E070 transport header extract.
Coverage Assessment	Substantially complete for identifying and sampling SAP changes where E070 is complete and accurate. Implementation Status: Implemented Up-to Sampling

Required Evidence / Uploads:

- SAP E070 table extract from the relevant production/change landscape.
- Production system name and Quality system name are entered in the UI.

Mandatory / Expected Columns:

- TRKORR – Transport / change number
- TRSTATUS – Transport/change status; released status is considered for population
- TARSYSTEM – Target system
- Optional: AS4USER, AS4TEXT for release user and description

Tool Logic:

- Reads the uploaded E070 extract.
- Identifies released transport/change records.
- Classifies changes based on available transport metadata and target system mapping.
- Supports sampling options such as review all, top 5, or random sample where available.

Output and Interpretation:

- Change population/samples displayed for audit review.
- Exceptions or missing column conditions are flagged.
- CM-01 audit trail can be exported.

CM-02 – Segregation of Duties – Developer vs Migrator

Item	Description
Control Area	Change Management
Objective	Ensure developers do not migrate their own changes to target systems, especially production.
Coverage Assessment	Substantially complete for direct same-user SOD conflict in the uploaded STMS population. It does not replace review of approval or emergency change evidence. Implementation Status: Implemented Completely

Required Evidence / Uploads:

- STMS import log / transport import history dump.

Mandatory / Expected Columns:

- TRKORR – Transport number
- OWNER – Developer / owner
- USER or ACTIONUSER – Migrator / importer

Tool Logic:

- Reads STMS extract.
- Compares developer/owner against migrator/import user.
- Flags instances where the same user appears as both developer and migrator.
- Provides STMS landscape guidance to help interpret DEV → QA → PRD movement.

Output and Interpretation:

- Exception table for same-user developer/migrator conflicts.
- Audit trail export for CM-02.

CM-03 – Developer Access to Production

Item	Description
Control Area	Change Management
Objective	Identify users with developer access in production to confirm that development capability is restricted outside production operations.
Coverage Assessment	Covered where the uploaded evidence reliably identifies production developer access. Auditor should confirm the extract source is production. Implementation Status: Implemented Completely

Required Evidence / Uploads:

- DEVACCESS or equivalent production extract.

Mandatory / Expected Columns:

- BNAME / USERNAME – User ID

- DEVCLASS / ACCESS TYPE – Indicator of developer access

Tool Logic:

- Reads production developer access evidence.
- Identifies users where developer access indicators are present.
- Reports such users as exceptions for review.

Output and Interpretation:

- List of users with developer access indicators.
- CM-03 audit trail export.

CM-04 – SCC4 Client Settings (OCR-Assisted Review)

Item	Description
Control Area	Change Management
Objective	Assist review of production SCC4 client settings against expected production restrictions.
Coverage Assessment	Assisted review only. OCR output is indicative; final conclusion must be manually validated against the screenshot and SAP screen. Implementation Status: Implemented Completely to be enhanced through AI

Required Evidence / Uploads:

- SCC4 screenshot from production.

Mandatory / Expected Columns:

- Not a structured CSV control. Uses screenshot OCR assistance.

Tool Logic:

- Reads visible screenshot text through OCR-assisted logic.
- Compares visible text with expected settings such as production role, no repository/cross-client changes, no client-specific changes, CATT/eCATT not allowed, and protected status.

Output and Interpretation:

- Indicative OCR-based observations and warnings.
- CM-04 audit trail export.

CM-05 – Table Logging & Modifiability (DD09L & DD02L)

Item	Description
Control Area	Change Management
Objective	Verify that relevant SAP tables have change logging enabled and are not directly modifiable in production.
Coverage Assessment	Covered for the uploaded DD09L/DD02L population. Completeness depends on whether the full relevant table population is uploaded. Implementation Status: Implemented Completely

Required Evidence / Uploads:

- DD09L extract for logging indicator.
- DD02L extract for table modifiability indicator.

Mandatory / Expected Columns:

- DD09L: TABNAME, PROTOKOLL
- DD02L: TABNAME, MAINTFLAG

Tool Logic:

- Matches tables between DD09L and DD02L by table name.
- Flags tables where logging is disabled or table modifiability indicates direct maintenance risk.

Output and Interpretation:

- Table-wise exception list.
- CM-05 audit trail export.

AM-01A – Access Creation

Item	Description
Control Area	Access Management
Objective	Ensure newly created SAP users are valid, authorized, approved, and supported by formal access request evidence.
Coverage Assessment	Covered for creation events present in SUIM. Approval evidence itself still needs auditor review outside the extract. Implementation Status: Implemented Completely

Required Evidence / Uploads:

- SUIM → Change Documents → For Users extract.

Mandatory / Expected Columns:

- SYSTEM
- CLIENT
- USERID
- CHANGE_TYPE
- CHANGED_ON
- CHANGED_AT
- CHANGED_BY
- FIELD
- OLD_VALUE
- NEW_VALUE
- ROLE
- PROFILE
- TICKET_ID
- REMARKS

Tool Logic:

- Identifies access creation events using CHANGE_TYPE = User Created.
- Groups same-timestamp default role additions with the user creation event to avoid double counting.
- Supports sampling options configured in AM-01 methodology.

Output and Interpretation:

- Access creation population/samples.
- Event grouping details.
- AM-01A audit trail export.

AM-01B – Access Modification

Item	Description
Control Area	Access Management
Objective	Ensure changes to existing SAP user access are authorized, approved, appropriate, and supported by valid evidence.
Coverage Assessment	Covered for modification activity captured in SUIM. Business justification and approval support should still be reviewed by the auditor. Implementation Status: Implemented Completely

Required Evidence / Uploads:

- SUIM → Change Documents → For Users extract.

Mandatory / Expected Columns:

- SYSTEM
- CLIENT
- USERID
- CHANGE_TYPE
- CHANGED_ON
- CHANGED_AT
- CHANGED_BY
- FIELD
- OLD_VALUE
- NEW_VALUE
- ROLE
- PROFILE
- TICKET_ID
- REMARKS

Tool Logic:

- Identifies access modification events such as user deletion, role removal, role addition, profile changes, user lock, and user unlock.
- Excludes user creation events from AM-01B.
- Groups multiple records for the same user/date/time as one modification event.

Output and Interpretation:

- Access modification population/samples.
- Detailed event grouping results.
- AM-01B audit trail export.

AM-02 – Terminated User Deactivation Within 24 Hours

Item	Description
Control Area	Access Management

Objective	Verify whether terminated users were removed, locked, or validity-restricted within the required timeline.
Coverage Assessment	Covered for HR-to-USR02 deactivation testing based on the actual client file headers. Failed cases require auditor follow-up and, where needed, SM20 review. Implementation Status: Implemented Completely

Required Evidence / Uploads:

- HR Exit file.
- USR02 user master extract.
- Optional SM20 logs for substantive follow-up on failed cases.

Mandatory / Expected Columns:

- HR Exit: Employee ID, Name, Designation, Department, Termination Date, Last Working Day, Ticket Request No, SAP User ID
- USR02: SAP User ID, User, Valid to, User Lock Status
- Optional SM20: User/BNAME/SAP User ID, Date/Log Date, Time/Log Time, Transaction/TCode, Action/Event

Tool Logic:

- Case 1: SAP User ID exists in HR Exit and exists in USR02 – test User Lock Status and Valid to date.
- Case 2: SAP User ID exists in HR Exit but does not exist in USR02 – display as No SAP ID Found.
- Case 3: SAP User ID is blank in HR Exit – display as No unique identifier found.
- Case 4: SAP User ID exists in USR02 but is not locked and Valid to is after deadline – Failed / follow-up required.
- Matching prioritizes HR Exit SAP User ID against USR02 SAP User ID and uses USR02 User/BNAME only as fallback.

Output and Interpretation:

- User-wise status: Complied, No SAP ID Found, No unique identifier found, or Failed.
- Reason field explaining the condition.
- Optional SM20 activity summary for failed cases.
- AM-02 audit trail export.

AM-03 – Password Policy Review (RSPARAM)

Item	Description
Control Area	Access Management
Objective	Compare SAP password parameter values against expected policy requirements.
Coverage Assessment	Covered for configured password parameters in the uploaded RSPARAM extract. Policy thresholds should be aligned with client policy before final conclusion. Implementation Status: Implemented Completely

Required Evidence / Uploads:

- RSPARAM parameter extract.

Mandatory / Expected Columns:

- Parameter Name
- User-Defined Value

Tool Logic:

- Reads RSPARAM parameter values.
- Compares key login/password parameters against defined expected values.
- Flags deviations for auditor review.

Output and Interpretation:

- Parameter-wise complied/deviation status.
- AM-03 audit trail export.

AM-04 – Privileged Access Review

Item	Description
Control Area	Access Management
Objective	Identify users with broad or sensitive SAP privileges across key administrative and configuration functions.
Coverage Assessment	Covered for the privilege sources uploaded. It identifies access presence; appropriateness, approval, and business need require auditor assessment. Implementation Status: Implemented Completely

Required Evidence / Uploads:

- SAP_ALL extract
- SAP_NEW extract
- SU01/SU02 extract
- SU10 extract
- STMS extract
- SCC4 extract
- SM30/SM31 extract
- SE06 extract
- SE38 extract

Mandatory / Expected Columns:

- Depends on extract type; user ID, user type, profile/role/authorization indicator, and evidence-specific privilege indicators are expected.

Tool Logic:

- Loads multiple privilege evidence files.
- Filters relevant user types where applicable, such as dialog/service accounts.
- Aggregates privileges by user and privilege category.
- Produces user-wise privileged access summary.

Output and Interpretation:

- User-wise privilege summary.
- Privilege source/evidence reference.
- AM-04 audit trail export.

OPS-01 – SAP Job Monitoring & Batch Processing

Item	Description
Control Area	IT Operations
Objective	Ensure critical SAP background jobs run successfully and issues are resolved timely.

Coverage Assessment	Covered for uploaded SM37 job monitoring population. Follow-up investigation evidence for failed jobs should be reviewed separately. Implementation Status: Implemented Completely
---------------------	--

Required Evidence / Uploads:

- SM37 job monitoring dump.

Mandatory / Expected Columns:

- JobName
- Spool list
- Job documentation
- Job CreatedBy
- Status
- Start date
- Start Time
- Duration(sec.)
- Delay (sec.)

Tool Logic:

- Reads the SM37 job monitoring dump.
- Validates that mandatory columns are present.
- Checks whether every job has Status = Finished.
- Any status other than Finished is reported as Failed / Not Finished.

Output and Interpretation:

- Summary of total jobs reviewed, finished jobs, and failed/not finished jobs.
- Table with all mandatory fields plus control result and observation.
- Automatic result CSV and OPS-01 audit trail export.

OPS-02 – SAP Backup and Recovery

Item	Description
Control Area	IT Operations
Objective	Future sub-control intended to assess SAP backup and recovery monitoring.
Coverage Assessment	Not implemented. Placeholder for future version.

Required Evidence / Uploads:

- Backup/recovery logs or evidence – not configured yet.

Mandatory / Expected Columns:

- Not configured yet.

Tool Logic:

- Placeholder only in current version.

Output and Interpretation:

- No automated output currently implemented.

End of PoC Document